

Manual Práctico de Mapeo de Controles y Cruces

Alberto Al Leiva

1 de agosto de 2026

Table of Contents

Control Mapping and Crosswalk Manual práctico

Nota de uso analítico y analítico: Una asignación no es prueba de cumplimiento, certificación, suficiencia jurídica, eficacia de control o garantía de auditoría. Verificar fuentes autorizadas, licencias, alcance, aplicación, pruebas y leyes aplicables.

Aviso de derechos y licencias: No reproduzca el texto de estándares propietarios sin autorización. Utilice identificadores de fuente autorizados y resúmenes analíticos autorizados por la organización cuando proceda.

Mapping Governance and Intended Use

1. Por qué la cartografía requiere gobernanza

Una cartografía de control es una relación analítica documentada entre dos o más requisitos, resultados, objetivos de control, prácticas, salvaguardias o expectativas de evidencia. Puede apoyar el diseño, el análisis, la reutilización, el análisis de brechas, la presentación de informes y la preparación de auditorías. No puede sustituir la fuente autorizada o demostrar que cualquier requisito está satisfecho.

Los mapas débiles crean falsa confianza. Pueden colapsar obligaciones distintas, ignorar las condiciones de alcance, ocultar cobertura parcial, o implicar que una implementación satisface cada requisito mapeado. Por lo tanto, un proceso de mapeo gobernado trata cada relación como una afirmación revisora apoyada por la racionalidad y la evidencia.

2. Definir el uso previsto antes de la asignación

Cada conjunto de cartografía debe indicar su uso previsto. Los usos comunes incluyen:

- diseñar un marco de control común;
- identificación de las implementaciones reutilizables;
- la preparación de un alcance de auditoría o evaluación;
- traducir los resultados ejecutivos en actividades de control;
- identificar lagunas o duplicar esfuerzos;
- apoyo a la presentación de informes sobre productos, proveedores o empresas;

- planificación de la migración entre versiones marco;
- conectar requisitos a pruebas y propiedad.

El uso previsto determina la precisión necesaria. Una comparación ejecutiva de alto nivel puede mapear categorías o resultados. Una asignación de apoyo a la auditoría requiere una descomposición de los requisitos, condiciones de alcance, referencias a la aplicación, expectativas de evidencia y un examen independiente.

3. Establecer autoridad cartográfica

El propietario de la cartografía es responsable de la metodología, la integridad de la fuente, la asignación del revisor, la aprobación, el mantenimiento y la jubilación. Los principales contribuyentes pueden proponer relaciones, pero la aprobación debe incluir a las personas que entienden tanto los dominios fuente como el entorno de aplicación real.

Las funciones recomendadas incluyen:

- **Mapping owner** — governs the mapping set and methodology;
- **Administrador de recursos** — confirma las versiones autorizadas y las limitaciones de licencias;
- **Revisor de dominio** - valida el significado de fuente y la aplicabilidad;
- **Propietario del control** - confirma el alcance de la aplicación y las pruebas;
- **Aprobador independiente**: desafíos de equivalencia sin apoyo;
- **Custodio de registros** — retiene versiones, decisiones y examina las pruebas.

4. Texto separado de la interpretación de la organización

Mantener campos distintos para:

1. el identificador fuente;
2. una fuente autorizada extracto o ubicación de referencia autorizada;
3. la interpretación concisa de la organización;
4. el objetivo de control normalizado;
5. la relación propuesta;
6. la racionalidad y las limitaciones.

Esta separación impide que un resumen autorizado por la organización se confunda en el idioma oficial. También permite corregir la interpretación sin cambiar el registro de origen.

5. Use tipos de relación explícitos

No utilice un único valor no diferenciado como “mapped”. Los tipos de relación recomendados son:

- **equivalente** — objetivos, alcance y resultado esperado son materialmente iguales;
- **La superposición fuerte** — existe una cobertura sustancial, pero una o más condiciones difieren;
- **La superposición parcial** - sólo se cubre parte del objetivo fuente;

- **apoya** - el objetivo contribuye al objetivo de la fuente pero no es suficiente solo;
- **** Relacionados**** - los temas abordan un tema común pero no establecen cobertura;
- **** Los conflictos o las limitaciones****: las obligaciones o las expectativas de aplicación requieren la reconciliación;
- **No mapear** — no se identificó ninguna relación defensible;
- **No se aplica** — se evaluó la aplicabilidad y se excluyó con racionalidad.

“Equivalente” debe ser raro y debe requerir una comparación documentada del alcance, actor, acción, objeto, condición, frecuencia, evidencia y resultado.

6. Confianza de registro por separado del tipo de relación

La fuerza de la relación y la confianza analista son diferentes. Una solapa parcial propuesta puede tener alta confianza; una equivalencia propuesta puede tener baja confianza.

Use una escala de confianza controlada como:

- **alta** - fuentes autorizadas y hechos de aplicación apoyan la conclusión, con un examen independiente;
- **medium** — la relación es razonable pero contiene condiciones de interpretación o no resueltas;
- **low** — la relación es preliminar, indirecta o basada en información incompleta.

Las cartografías de baja confianza no deben impulsar las reclamaciones de cumplimiento ni las decisiones de reutilización de control sin más revisión.

7. Alcance prefabricado y aplicabilidad

Un registro de mapas debería determinar las dimensiones pertinentes del alcance, entre ellas:

- jurídica y jurisdicción;
- procesos y servicios empresariales;
- sistema, aplicación, infraestructura o instalación;
- tipo de datos y sensibilidad;
- mano de obra, proveedor o población de clientes;
- modelo tecnológico, incluidos los límites de responsabilidad en la nube;
- período de evaluación;
- grupo de aplicación, perfil, nivel de referencia o nivel de garantía;
- disparadores contractuales y regulatorios.

Una relación puede ser válida en un ámbito e inválida en otro.

8. Criterios de aprobación

No debe aprobarse una asignación a menos que:

- ambas fuentes y versiones se identifican;
- se respetan las limitaciones de licencias y reproducción de origen;

- las necesidades se descomponen a un nivel comparable;
- se registran el alcance y la aplicabilidad;
- tipo de relación y confianza son explícitas;
- rationale identifica tanto la cobertura como las limitaciones;
- - a) Los vínculos entre la aplicación y las pruebas se distinguen de las relaciones de origen;
- los conflictos y las lagunas son visibles;
- a independent reviewer has recorded a decision;
- a revisión gatillo y fecha de caducidad se asignan.

9. Reclamaciones prohibidas

No diga que:

- la aplicación de un marco establece automáticamente el cumplimiento de otro;
- a mapping proves design or operating effectiveness;
- a crosswalk es una opinión legal o certificación;
- una relación de categoría de alto nivel satisface los requisitos detallados;
- La terminología idéntica significa obligación idéntica;
- un mapeo proporcionado por proveedores elimina el deber de la organización de validar el alcance y la implementación.

10. Pruebas mínimas de gobernanza

Retener:

- metodología aprobada y definiciones de relación;
- registro de fuentes e historial de versiones;
- mapear registros y racionalidad;
- - Comentarios de los examinadores y decisiones de aprobación;
- conflictos, excepciones y lagunas no resueltas;
- cambio de registros y cartografías retiradas;
- pruebas de un examen periódico y basado en eventos.

Descomposición y Normalización de Requisitos

1. Mapa unidades comparables

Los exámenes fallan cuando los analistas comparan unidades a diferentes niveles. Un resultado marco amplio no puede considerarse equivalente a un requisito técnico detallado simplemente porque ambos se refieren al mismo tema. Antes de mapear, descomponga cada fuente en unidades analíticas comparables.

Un modelo de requisito útil se separa:

- **actor** - quien debe actuar o seguir siendo responsable;
- **acción** - qué debe establecerse, ejecutarse, prohibirse, revisarse o demostrarse;
- **objeto**: el sistema, la información, el proceso, la persona, el proveedor, las instalaciones o los registros afectados;
- **condición**: cuándo, dónde o bajo qué disparador se aplica el requisito;
- **frecuencia o calendario** — con qué frecuencia o dentro de qué período se espera la adopción de medidas;
- **** umbral de calidad**** - requiere rigor, integridad, independencia o rendimiento;
- **Esperanza de la evidencia** - qué registros podrían demostrar la implementación o operación;
- **** fuera de lugar****: la protección prevista, el resultado de la gobernanza o el objetivo de garantía;
- **** excepciones****: alternativas explícitas, mecanismos compensatorios o límites de aplicabilidad.

2. Preserve source identity

Cada unidad descompuesta debe conservar su identificador y versión de origen padre. No asigne un nuevo identificador que obscure la referencia autorizada. Si una organización crea subelementos para el análisis, utilice un sufijo transparente como ORG-SEG-01 y registre que es un segmento analítico, no un identificador de fuente oficial.

3. Tipos de requisitos distinguidos

Clasifique la unidad fuente antes de normalizarla. Los tipos comunes incluyen:

- obligación de gobernanza;
- requisito de política o procedimiento;
- actividad de gestión del riesgo;
- salvaguardia técnica;
- salvaguardia física;
- - Requisitos laborales o de capacitación;
- requisito del proveedor;
- requisitos de vigilancia o detección;

- necesidad de respuesta o recuperación;
- principio de privacidad o derecho individual;
- documentación o requisito de retención;
- evaluación, ensayo o requisito de garantía;
- obligación de notificación o notificación.

Los requisitos de diferentes tipos pueden apoyarse unos a otros sin ser equivalentes.

4. Escribe un objetivo de control normalizado

Un objetivo normalizado debe ser conciso, neutral desde el punto de vista tecnológico, y fiel a la fuente. Use esta estructura:

The organization [action] [object] [condition or scope] to achieve [outcome], with [timing, quality, or evidence condition].

El objetivo normalizado es una ayuda analítica. No debe reemplazar ni parafrasear a los calificadores legalmente significativos.

5. Retener los calificativos obligatorios

Palabras como “deberán”, “deber”, “al menos anualmente”, “sin demora indebida”, “razonable”, “apropiado”, “independiente” y “documentado” pueden alterar materialmente la obligación. Grabar estos calificativos en campos dedicados o en las notas de interpretación. No los normalice simplemente para hacer que dos elementos parezcan similares.

6. Handle outcome-based and prescriptive sources

Los marcos basados en los resultados describen los resultados deseados y pueden permitir múltiples implementaciones. Las fuentes prescriptivas pueden especificar métodos, frecuencias, tecnologías o registros. Un requisito prescriptivo puede ser un camino de aplicación hacia un resultado, pero el resultado no satisface necesariamente el detalle prescriptivo.

Recordar la relación como “apoyos”, “aplauzo parcial”, u otro tipo calificado a menos que todas las condiciones relevantes se alinean.

7. Manage source granularity

Use una etiqueta de granularidad:

- función marco o dominio;
- categoría o objetivo;
- control de la familia;
- control o requisito;
- mejora del control o subrequerimiento;
- Declaración de aplicación;
- procedimiento de evaluación;
- atributo de evidencia.

Los registros de mapeo deben comparar normalmente los mismos niveles de granularidad adyacentes. Se pueden conservar mapas de alto nivel para la navegación, pero no deben utilizarse como afirmaciones detalladas de cumplimiento.

8. Identificar diferencias de alcance oculto

Dos requisitos pueden parecer similares mientras que difieren en:

- tipo de datos protegidos;
- entidad cubierta o actor regulado;
- sistemas internos versus externos;
- la producción frente a los entornos de desarrollo;
- todos los activos contra activos de alto riesgo;
- requisito de diseño versus requisito operativo;
- - existencia de políticas contra pruebas de aplicación;
- objetivo preventivo contra detective;
- alcance de toda la organización frente al sistema específico.

Documentar estas diferencias antes de asignar fuerza de relación.

9. Controles de calidad de la descomposición

Un requisito descompuesto está listo para el mapeo cuando:

- la fuente y la versión oficiales son rastreables;
- la unidad es comprensible sin cambiar su significado;
- se mantienen los calificativos obligatorios;
- las condiciones de aplicabilidad son explícitas;
- se determina el nivel de granularidad;
- el objetivo normalizado es separado del lenguaje fuente;
- se respetan las restricciones a la concesión de licencias;
- un analista puede explicar qué evidencia y no demostraría el objetivo.

Análisis de relaciones y decisiones de cobertura

1. Comparar dimensiones, no palabras clave

Una decisión de relación defensible compara significado a través de múltiples dimensiones. La similitud de palabras clave es sólo una ayuda de descubrimiento. Para cada asignación propuesta, compare:

- finalidad y resultados previstos;
- y rendición de cuentas;
- objeto o proceso protegido;

- alcance y aplicabilidad;
- medidas necesarias;
- tiempo y frecuencia;
- especificidad de la aplicación;
- expectativa de pruebas;
- excepción o condiciones alternativas;
- garantía o requisito de independencia.

2. Determinación de la dirección

Las maquetas no son automáticamente simétricas. Un objetivo detallado puede satisfacer parte de un objetivo de amplia fuente, mientras que la fuente amplia no satisface las condiciones detalladas del objetivo. Dirección de registro explícitamente:

- fuente a objetivo;
- objetivo a fuente;
- bidireccional sólo después de la validación separada en ambas direcciones.

3. Cobertura de evaluación

Use una decisión de cobertura respaldada por racionalidad:

- **completo para el alcance declarado:** todo elemento material se aborda dentro del ámbito registrado;
- **sustancial** — la mayoría de los elementos materiales se abordan, con condiciones residuales limitadas;
- **** parcial**:** se abordan elementos significativos, pero persisten lagunas materiales;
- **minimal** - sólo se aborda un pequeño componente o actividad de habilitación;
- **None** — no existe cobertura defensible.

La cobertura debe evaluarse independientemente de la madurez de la aplicación. Una relación teóricamente completa puede todavía no tener control implementado o evidencia usable.

4. Maneja las relaciones de uno a otro

Un requisito de origen puede requerir varios controles de destino. Cree cualquiera:

- filas de mapeo separadas vinculadas por un identificador de grupo de relación común; o
- a parent relationship record with child mappings.

No marque a ningún niño como completo si la cobertura completa depende del grupo. Registrar la regla de agregación y la brecha residual.

5. Maneja muchas relaciones a una

Un control objetivo puede soportar varios requisitos de origen. La reutilización puede ser eficiente, pero validar cada relación independientemente porque el alcance, el período de evidencia, el actor y las condiciones de calidad pueden diferir.

6. Identificar enfoques compensatorios y alternativos

Una medida compensatoria no es un equivalente automático. Grabación:

- el objetivo original;
- por qué el método primario es infeasible o inapropiado;
- la aplicación alternativa;
- rigor y protección comparables;
- autorización;
- vigilancia y expiración;
- Condiciones de aceptación específicas de la fuente.

Cuando una fuente define un proceso formal de compensación-control, siga ese proceso en lugar de depender de una etiqueta de asignación genérica.

7. Conflictos y limitaciones récord

Los golpes deben exponer, no ocultar, conflictos. Por ejemplo:

- diferentes períodos de retención;
- - c) Plazos de notificación incoherentes;
- restricciones regionales de localización de datos;
- diferentes frecuencias de prueba;
- - las expectativas de acceso o segregación incompatibles;
- formatos de prueba específicos para fuentes;
- restricciones legales a la vigilancia o los datos laborales.

Conflictos de ruta a propietarios legales, de privacidad, cumplimiento, seguridad o negocios calificados. Un analista de cartografía no debe resolver un conflicto legal al elegir el requisito menos restrictivo.

8. Confianza de la firma

La confianza debe reflejar la calidad de las pruebas, la experiencia de los examinadores, la ambigüedad y la moneda de origen. Record reasons for medium or low confidence and prohibit unsupported high-confidence defaults.

9. Require rationale that can be challenged

Una racionalidad útil explica:

- el objetivo común;
- los elementos de coincidencia;
- los elementos no palpables;
-

- Hipótesis de alcance;
- de las dependencias de aplicación;
- deficiencias residuales;
- por qué los niveles de relación y cobertura seleccionados son apropiados.

Evite afirmaciones tales como “mismo tema”, “estándar de la industria”, o “comúnmente mapeado” sin análisis.

10. Examen independiente

El revisor debe ser capaz de rechazar, calificar o dividir una asignación propuesta. El examen debe abordar la fidelidad de la fuente, la granularidad, el alcance, el tipo de relación, la cobertura, la confianza, la concesión de licencias y el uso previsto. Debe mantenerse la decisión y las observaciones.

Implementación, evidencia y enlace de control común

1. Mantenga tres capas de relación separadas

Un modelo de mapeo maduro distingue:

1. ** Cartografía de fuente a fuente **: la relación analítica entre requisitos externos o elementos marco;
2. ** Cartografía de fuente a control ** - cómo se pretende un control de organización abordar un objetivo fuente;
3. ** mapeo de control a evidencia ** — qué registros demuestran diseño, implementación y operación.

Combinar estas capas en un campo crea ambigüedad y puede convertir un cruce teórico en una reclamación de cumplimiento sin soporte.

2. Definir el control de la organización

Un registro de control de las organizaciones debe identificar:

- identificador de control y título;
- declaración objetiva y de control;
- propietario y operador;
- alcance y límites heredados;
- prevención, detective, correctivo, directiva o tipo de recuperación;
- operación manual, automatizada o híbrida;
- frecuencia y gatillo;
- sistemas, datos, procesos y poblaciones abarcadas;
- dependencias y excepciones;
- pruebas esperadas;
- enfoque de pruebas y estado.

3. Validar la reutilización del control común

Un control común puede apoyar varios sistemas o requisitos. La reutilización es defensible sólo cuando se identifica el alcance consumidor y se valida la herencia. Grabación:

- Proveedor de control común;
- consumidores;
- servicios o límites cubiertos;
- responsabilidades que mantiene el consumidor;
- disponibilidad de pruebas;
- período de funcionamiento;
- excepciones y suplementos locales;
- el gatillo de aprobación y reevaluación.

4. Diseño distinguido de la operación

Una política, arquitectura o procedimiento puede demostrar intención de diseño. No prueba por sí mismo que un control funcionaba eficazmente. Los tipos de pruebas pueden incluir:

- los documentos normativos y de procedimiento aprobados;
- exportaciones de configuración;
- registros generados por el sistema;
- entradas y aprobaciones;
- - c) Registros de terminación de la capacitación;
- inventarios y conciliaciones;
- vigilar los resultados;
- pruebas y registros de ejercicios;
- registros de excepción;
- documentos de trabajo independientes de evaluación.

Recordar si la evidencia apoya el diseño, la implementación, la eficacia operativa, o sólo la comprensión contextual.

5. Pruebas coinciden con el requisito de mapeado

Las pruebas aceptables para una fuente pueden ser insuficientes para otra debido a diferencias en el período, muestreo, independencia, retención, detalle técnico o cobertura poblacional. Cada relación fuente debe identificar sus condiciones de evidencia en lugar de heredarlas automáticamente del control común.

6. Pruebas de frescura y linaje

Las referencias a las pruebas deben incluir:

- repositorio o sistema de registro;
- propietario y custodio;

- fecha de recogida y período abarcado;
- linaje del sistema fuente;
- verificación de integridad e integridad;
- restricciones de acceso;
- período de retención;
- revisor y fecha de revisión;
- limitaciones conocidas.

7. Gestionar modelos de responsabilidad compartida

Para la nube, los servicios gestionados y los proveedores, distinguir:

- responsabilidad del proveedor;
- responsabilidad del cliente;
- actividad compartida;
- pruebas heredadas;
- obligación de configuración o monitoreo del cliente;
- limitaciones contractuales de seguridad.

Una certificación o reporte de proveedores puede apoyar un requisito pero rara vez elimina las responsabilidades del cliente.

8. Evitar la denuncia

No marque un requisito satisfecho simplemente porque existe un artefacto de evidencia. Confirme que el artefacto es auténtico, completo, relevante, dentro del período, dentro del alcance, y conectado a la operación de control real.

9. Link findings and exceptions

Cuando la aplicación o las pruebas estén incompletas, vincule el registro de asignación a:

- registro de brechas;
- excepción o registro de aceptación de riesgos;
- plan de rehabilitación;
- propietario y fecha de vencimiento;
- salvaguardia provisional;
- pruebas de validación;
- decisión de cierre.

10. Reporting language

Use lenguaje como:

- “el control está destinado a apoyar...”;
- “la evidencia disponible indica...”;
- “la cobertura es parcial porque...”;

- “Se requiere validación adicional...”;
- “la asignación no establece el cumplimiento.”

Evite las reclamaciones categóricas no respaldadas por pruebas de evaluación.

Gap, Overlap, Conflict, and Prioritization

1. Trate de mapeo como análisis, no decoración

El valor de un cruce no es el número de células de color. Es la capacidad de exponer cuando las obligaciones están cubiertas, duplicadas, sin apoyo, ambiguas o en conflicto.

2. Identificar tipos de diferencias

Clasifique las lagunas para que la rehabilitación pueda ser asignada correctamente:

- **Desfase de las necesidades** — ningún control de las organizaciones aborda un objetivo fuente;
- **Desfase del telescopio**: existe un control pero no abarca todos los sistemas, datos, entidades o poblaciones requeridos;
- **Desfase de diseño**: la declaración o procedimiento de control omite una condición material;
- **Desfase de ejecución**: el control diseñado no se despliega ni se realiza sistemáticamente;
- **La brecha de incidencia** — la operación puede existir, pero no se dispone de pruebas suficientes;
- **La brecha de seguridad** - falta independencia, pruebas, muestreo o presentación de informes;
- **La brecha de propiedad** — la rendición de cuentas no está clara;
- **Desfase de la inversión**: la asignación depende de fuentes superpuestas o de identificadores modificados;
- **La brecha de reducción** — los derechos de uso o reproducción de fuentes no se resuelven.

3. Identificar superposiciones

Las superposiciones pueden indicar una reutilización eficiente o una duplicación innecesaria. Recordar si la superposición es:

- Reutilización intencional de control común;
- - Protección complementaria de capas;
- actividad de control duplicada;
- duplicar la recopilación de pruebas;
- duplicar las actividades de evaluación;
-

- La propiedad en conflicto;
- aplicación incoherente del mismo objetivo.

No retire los controles de superposición únicamente para simplificar el mapa. La defensa en profundidad, la segregación, el alcance jurisdiccional o la garantía independiente pueden justificar la superposición.

4. Analizar conflictos

Un registro de conflictos debe identificar:

- los requisitos de la fuente de competencia;
- - Alcance y jurisdicción afectados;
- tipo de conflicto;
- interpretación más estricta posible;
- autoridad competente en materia de decisiones;
- revisión jurídica o contractual necesaria;
- salvaguardia provisional;
- la decisión y la justificación;
- fecha de revisión y gatillo.

5. Priorizar la rehabilitación

La prioridad debe considerar:

- mandato jurídico o contractual;
- los datos afectados y el servicio crítico;
- amenaza y exposición a la vulnerabilidad;
- impacto empresarial;
- amplitud de la cobertura marco;
- fecha de evaluación o renovación;
- la dependencia de control;
- disponibilidad de pruebas;
- esfuerzo y secuenciación;
- tratamiento provisional de riesgo.

Una brecha que afecta a muchos requisitos mapeados puede ser una remediación de alto nivel, pero la amplitud por sí sola no anula la urgencia legal ni la gravedad del riesgo.

6. Evite la doble contabilización

Una brecha de control subyacente puede crear muchas lagunas a nivel de fuente. Preserve cada relación fuente para la trazabilidad, pero vinculen con una causa raíz común y un registro de remediación. Esto evita que el problema inflado cuente mientras mantiene la visibilidad del requisito.

7. Informe sobre la incertidumbre residual

Report mapping uncertainty separate from implementation gaps. Una relación de baja confianza puede requerir aclaración de la fuente incluso cuando el control está operando eficazmente.

8. Presentación de informes

Los informes útiles incluyen:

- cartografías aprobadas por relación y confianza;
- requisitos sin asignación;
- cartografías parciales con condiciones residuales materiales;
- las lagunas de control agrupadas por la causa raíz;
- - actividades duplicadas o solicitudes de pruebas;
- conflictos no resueltos;
- maps due for review;
- cambios causados por actualizaciones de la conversión de fuentes;
- estado de remediación y decisiones atrasadas.

No presente un porcentaje de requisitos mapeados como porcentaje de cumplimiento.

Review, Change Control, and Retirement

1. Treat mappings as controlled records

Un conjunto de mapeo es un producto analítico versionado. Debe tener un propietario, metodología aprobada, identificador de liberación, fecha efectiva, manifiesto de fuente, registro de revisión, registro de cambios y proceso de jubilación.

2. Establecer los desencadenantes del examen

Revisión de mapas cuando:

- o cambios en el marco de origen o la reglamentación;
- se expide una interpretación oficial, erratum o enmienda;
- cambian los identificadores de origen o las estructuras de control;
- los cambios de diseño de control de la organización;
- cambios en el alcance del sistema, el servicio, los datos, la entidad o la jurisdicción;
- cambio de los arreglos de responsabilidad compartida o de proveedores;
- los resultados de las auditorías ponen en tela de juicio una relación;
- Las pruebas demuestran que un control asumido no funciona según lo previsto;
- cambio de las condiciones de concesión de licencias o acceso a fuentes;
- el uso previsto de los cambios de mapeo.

También asigne una fecha de examen periódico incluso cuando no se produzca ningún evento.

3. Análisis de impacto

Para cada cambio, identifique:

- los conjuntos y filas de cartografía afectados;
- cambio de significado fuente o identificador;
- controles de las organizaciones afectadas;
- pruebas y pruebas impactadas;
- - las lagunas creadas o cerradas;
- informes, paneles, políticas y documentos de trabajo de auditoría que dependen de la asignación;
- usuarios que deben ser notificados;
- si las conclusiones anteriores siguen siendo válidas.

4. Conjuntos de asignación de versiones

Use un esquema de versión controlada. Una versión importante puede reflejar cambios de metodología o estructura de fuentes; una versión menor puede reflejar adiciones o correcciones aprobadas. Grabar las versiones de fuente exactas incluidas en cada versión.

No sobrescribir un mapeo histórico aprobado sin preservar el estado anterior.

5. Revalidate hereed and imported mappings

Los mapas externos pueden acelerar el análisis, pero siguen siendo afirmaciones de terceros. Antes de la adopción:

- identificar la editorial y la metodología;
- confirmar las versiones de fuentes;
- examinar la concesión de licencias y la atribución;
- test representative relations;
- - i) Determinar las hipótesis de alcance;
- document local modifications;
- asigne propiedad y aprobación interna.

6. Retire cartografías de forma segura

La jubilación es apropiada cuando se retira una fuente, se invalida una relación, se termina el uso previsto o se aprueba una asignación de reemplazo. Un registro retirado debe conservar:

- Fecha de jubilación;
- razón;
-

- a) Aprobación de autoridad;
- c) Registro o versión de sustitución;
- informes y usuarios afectados;
- período de retención;
- advertencia contra uso futuro.

7. Errores correctos transparentemente

Cuando un mapeo aprobado se encuentra equivocado:

1. suspender las reclamaciones o los informes afectados;
2. identificar el uso de aguas abajo;
3. corregir la asignación con pruebas de revisión;
4. notificar a los usuarios pertinentes;
5. reevaluar las lagunas, los controles y las conclusiones de la auditoría;
6. conservar el historial de corrección.

8. Muestra de garantía de calidad

Registros de mapeo de muestras periódicas para:

- versiones actuales de fuentes;
- identificadores completos;
- la granularidad correcta;
- dirección explícita y tipo de relación;
- confianza favorable;
- racionalidad y limitaciones;
- enlaces válidos de aplicación y pruebas;
- examen independiente;
- fechas de examen oportunas;
- ausencia de reclamaciones de cumplimiento prohibidas.

9. Criterios de liberación

Un lanzamiento de cartografía debe fallar cerrado si:

- faltan los registros de fuentes necesarios;
- El texto patentado se incluye sin una base de acceso establecida;
- las definiciones de relación son inconsistentes;
- c) Las cartografías no revisadas están representadas como aprobadas;
- quedan los titulares de puestos sin resolver;
- se desconocen las versiones de origen;
- se omite la confianza o las limitaciones;

- fallan los controles de integridad de salida.

10. Límites de revisión humana

Automatización puede verificar los recuentos de campo, identificadores, fechas, valores requeridos, referencias rotas, integridad de checksum, estructura de documentos y algunas reglas de consistencia. No puede determinar la equivalencia legal, interpretar las normas patentadas de manera autorizada, validar la matización en lengua nativa o sustituir el juicio de auditoría y control calificado.

Autoritative Source Register

Verificado 1 de agosto de 2026. Este registro registra identidad y versión de origen; no reproduce texto de normas patentadas.

Fuentes primarias

1. **NIST Marco de seguridad cibernética 2.0** — Instituto Nacional de Normas y Tecnología, publicado en febrero de 2024. Marco oficial y recursos de referencia: <https://www.nist.gov/cyberframework>
2. **NIST SP 800-53 Rev. 5, Release 5.2.0** — *Controles de seguridad y privacidad para sistemas y organizaciones de información*. NIST nota de planificación fechada 27 agosto 2025 registros Release 5.2.0: <https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>
3. **CIS Controles de seguridad críticos v8.1** — Center for Internet Security. Página oficial v8.1 y materiales descargables: <https://www.cisecurity.org/controls/v8-1>
4. **CIS Controles Navigator v8.1** — recurso oficial de asignación interactiva: <https://www.cisecurity.org/controls/cis-controls-navigator>
5. **ISO/IEC 27001:2022** — * Sistemas de gestión de la seguridad de la información — Requisitos*. Página oficial del ciclo de vida ISO: <https://www.iso.org/standard/27001.html>
6. **ISO/IEC 27001:2022/Amd 1:2024** — Enmienda de la acción climática, publicada en febrero de 2024: <https://www.iso.org/standard/88435.html>
7. **PCI DSS v4.0.1** — PCI Security Standards Council document library, June 2024: https://www.pcisecuritystandards.org/document_library/?class=pcidss&doc=pci_dss
8. **HIPAA Regla de seguridad** — Departamento de Salud y Servicios Humanos de los Estados Unidos, norma actual en 45 CFR Parte 160 y Parte 164, Subpartes A y C: <https://www.hhs.gov/hipaa/for-professionals/security/index.html>
9. **Regulación (UE) 2016/679 (GDPR)** — texto normativo consolidado oficial: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>

Controles de uso de fuentes

- Verifique las versiones de origen antes de crear o aprobar una asignación.
- Retener el identificador fuente, título, editor, versión, fecha de publicación, fecha de recuperación y ubicación autorizada.
- Use copias con licencia donde un estándar no sea reproducible libremente.

- Record organization-authored summaries separately from official source text.
- No inferir equivalencia simplemente porque dos requisitos utilizan palabras similares.
- Examinar mapas cuando cambie la fuente o cuando cambie el alcance de la aplicación.